



A Arte de Enganar a Mente

Exercício Prático de Engenharia Social

Pedro Costa
pedro.osorio@ua.pt



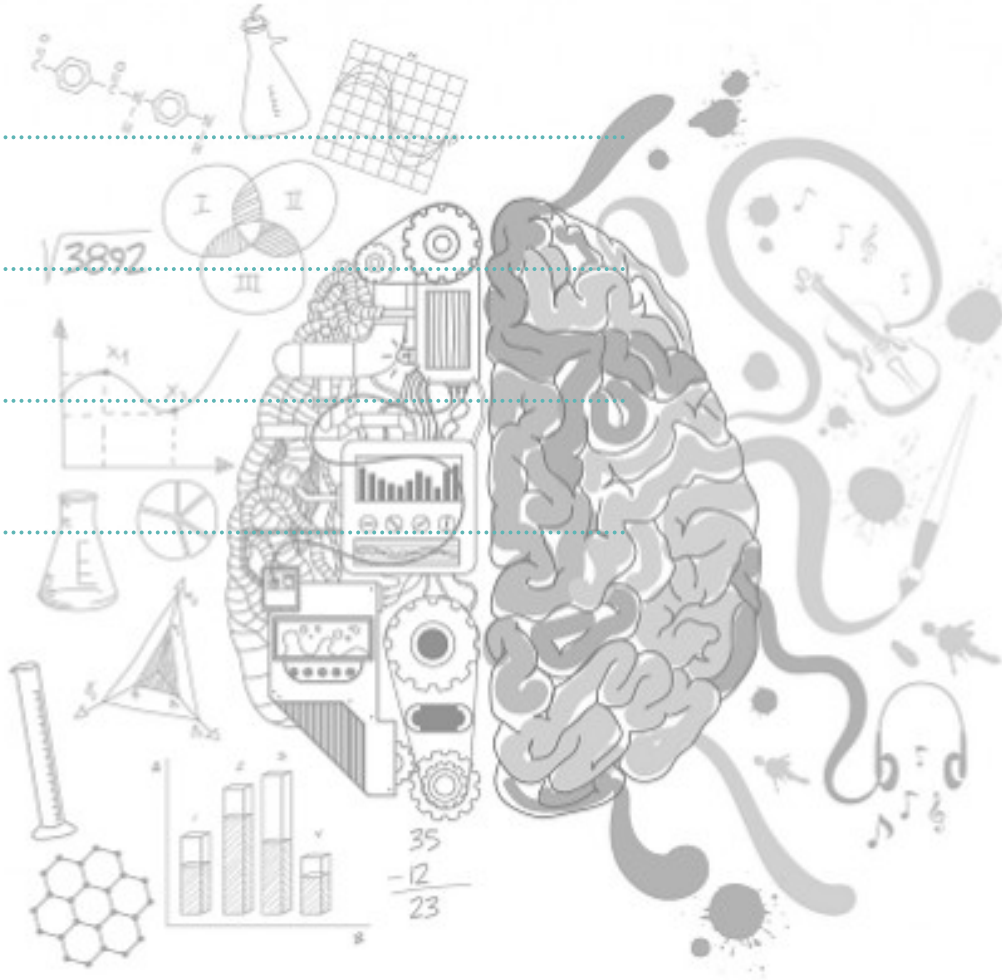
AGENDA

Princípios psicológicos

Engenharia Social

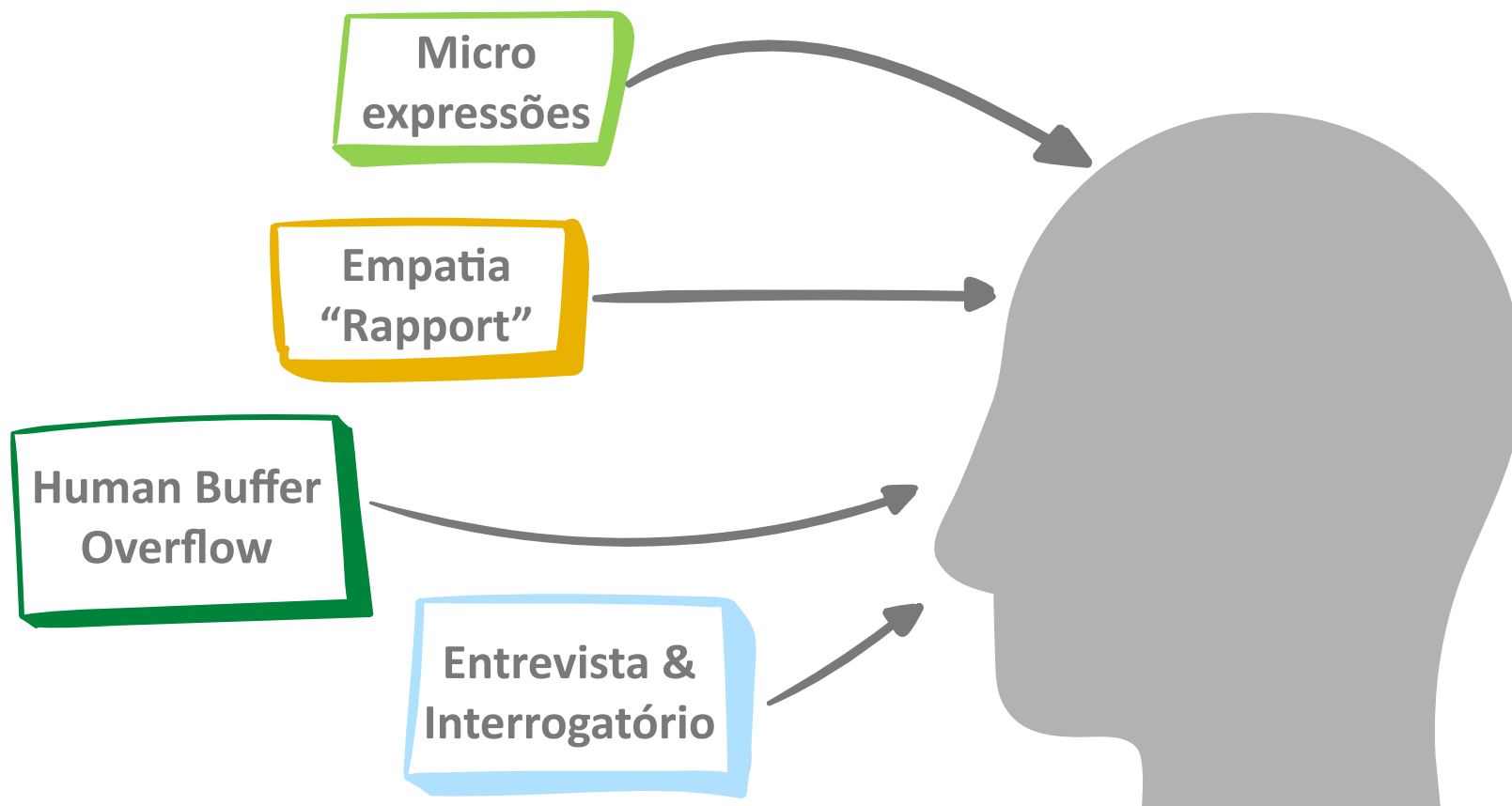
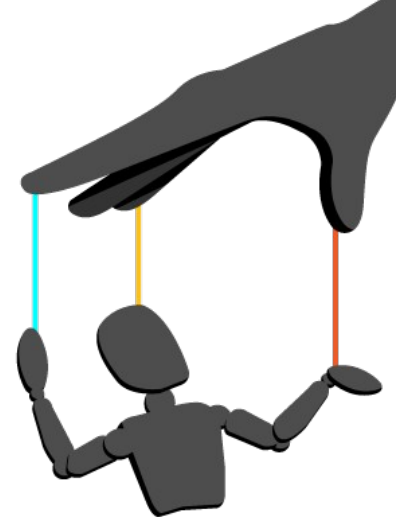
Exercício prático de Phishing

Conclusões



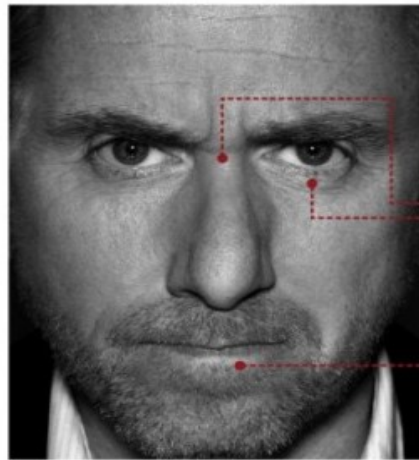
PRINCÍPIOS PSICOLÓGICOS

No contexto da segurança da informação, a **engenharia social** permite a **manipulação psicológica** de pessoas para realizar acções ou divulgar informações confidenciais



PRINCÍPIOS PSICOLÓGICOS

Exemplos de micros expressões:



anger

- ① eyebrows down and together
- ② eyes glare
- ③ narrowing of the lips



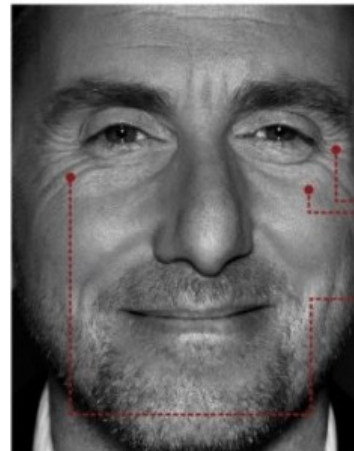
sadness

- ① drooping upper eyelids
- ② losing focus in eyes
- ③ slight pulling down of lip corners



fear

- ① eyebrows raised and pulled together
- ② raised upper eyelids
- ③ tensed lower eyelids
- ④ lips slightly stretched horizontally back to ears



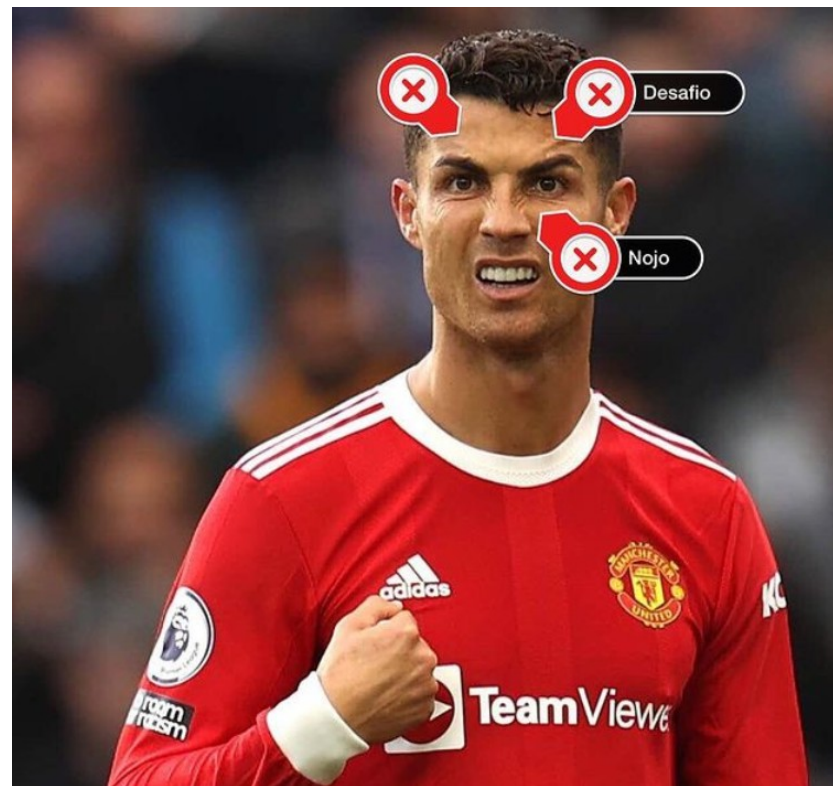
happiness

- A real smile always includes:
- ① crow's feet wrinkles
 - ② pushed up cheeks
 - ③ movement from muscle that orbits the eye

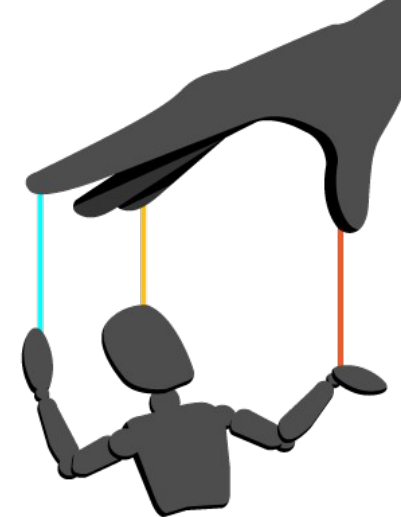


PRINCÍPIOS PSICOLÓGICOS

Exemplos de micros expressões:



Fonte: Alexandre Monteiro



The Human Buffer Overflow aka Amygdala Hijacking

AMARELO

PRETO

ROSA

LARANJA

AZUL

VERDE

AZUL

VERMELHO

AMARELO

VERDE

VERMELHO

AZUL

LARANJA

VERDE

VERMELHO

PRETO

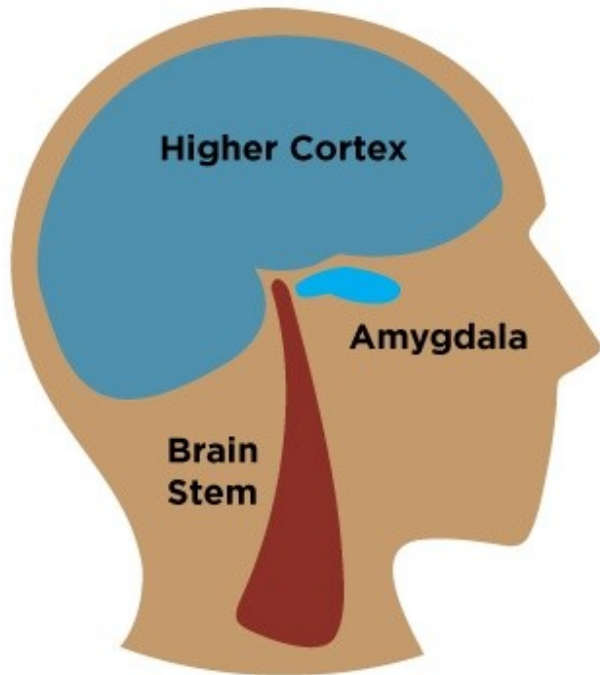
ROSA

LARANJA

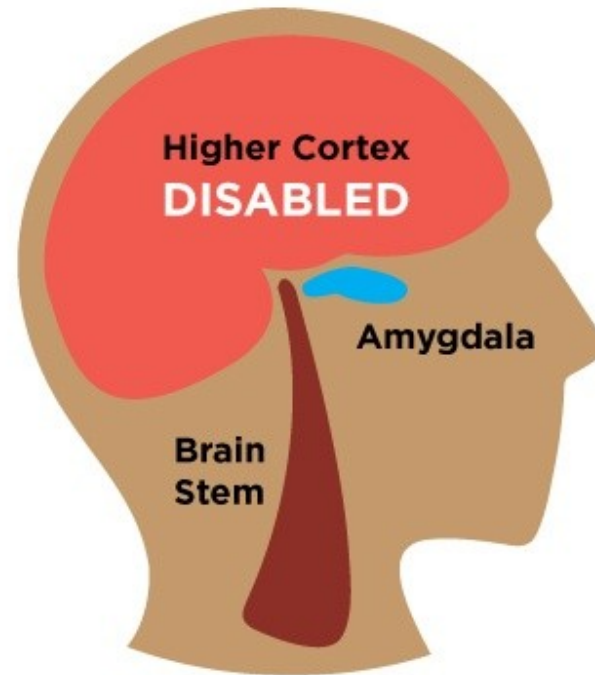
É possível executar “código” no cérebro
que pode ser o oposto ao que a pessoa está a pensar ou a ver.



PRINCÍPIOS PSICOLÓGICOS



LOW Emotion
(Calm, Relaxed)



HIGH Emotion
(Anger, Fear, Excitement, Love,
Hate, Disgust, Frustration)



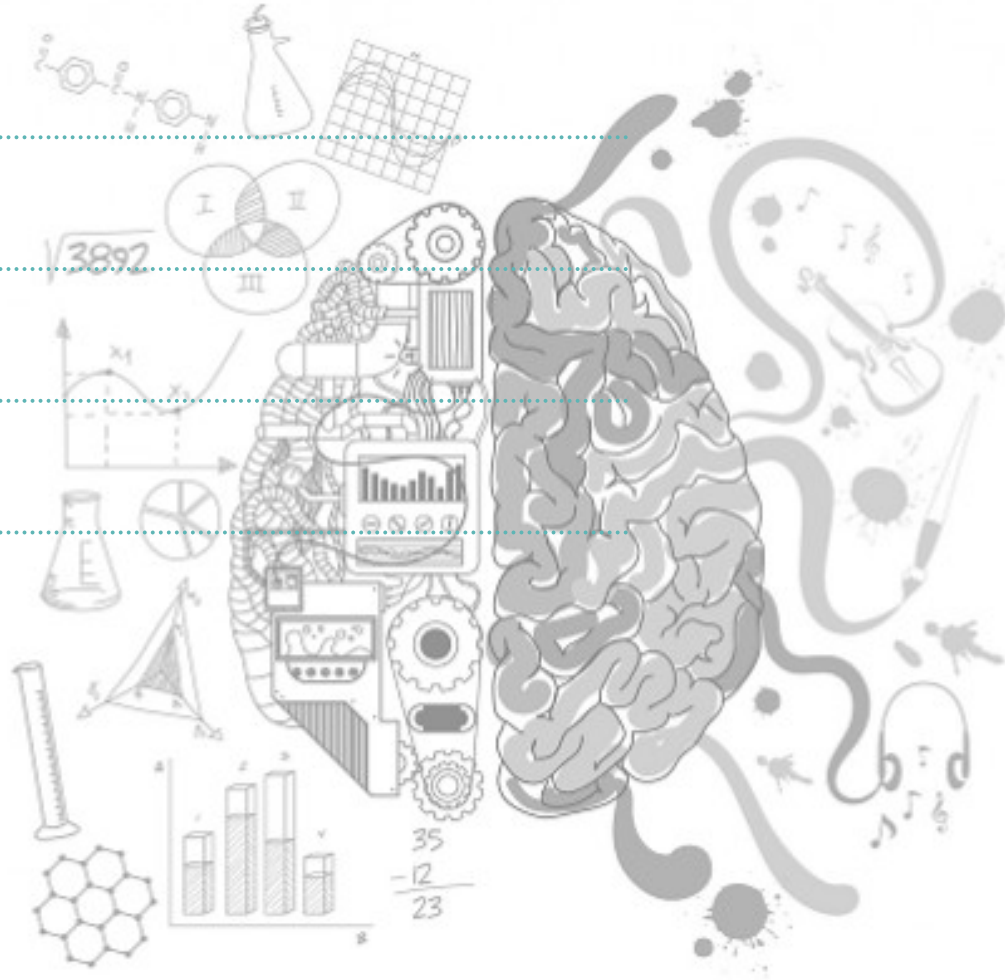
AGENDA

Princípios psicológicos

Engenharia Social

Exercício prático de Phishing

Conclusões



QUEM É O ELO MAIS FRACO?



O ser humano. Porquê?

Pensamos por nós próprios. Livre-arbítrio.

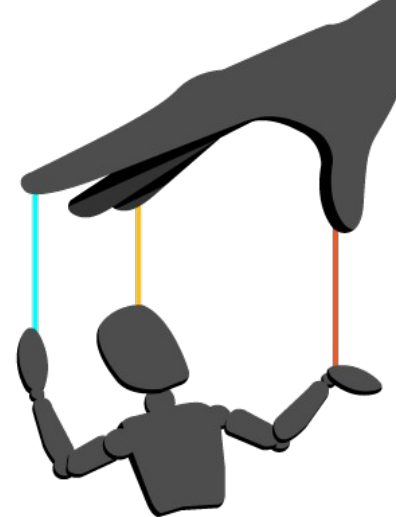
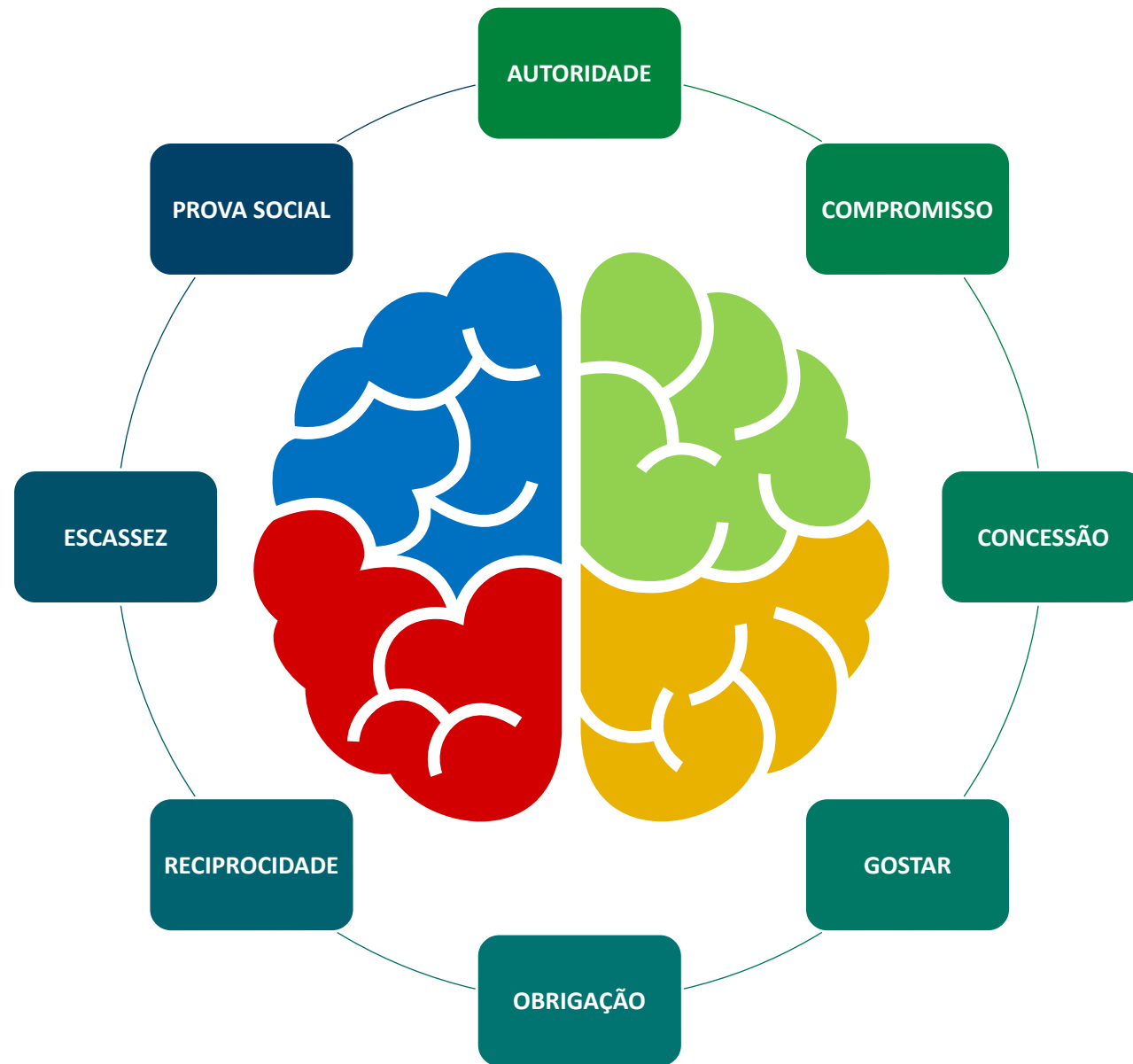
Mais propensos ao erro. “Errar é Humano”

Em geral não lidamos bem com o stress

Sistemas de segurança mais sofisticados

Engenharia Social

ASPETOS QUE INFLUENCIAM O SER HUMANO



CICLO DE VIDA: ENGENHARIA SOCIAL

Obtenção de Informação

- Contatos (telefone, email, ...)
- Dados sobre a sua vida profissional
- Rede de contatos e suas ligações
- Informação pessoal (fotos, interesses, ...)

Estabelecer relação

- Estabelecer relação de confiança com a vítima com base na informação obtida previamente

Executar / Explorar

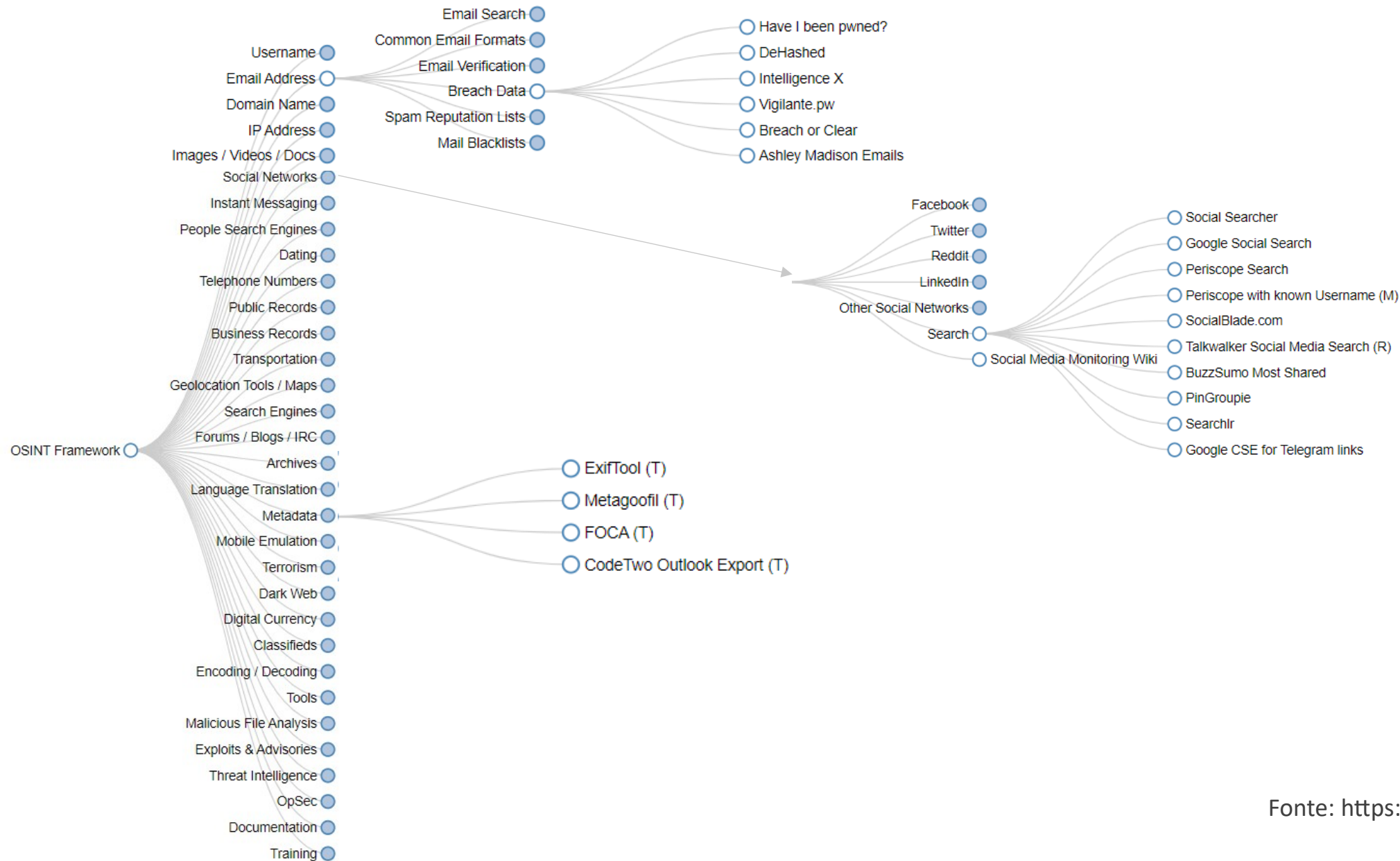
- Utilização e execução de técnicas de ataque (Phishing, Vishing, ...)
- Extrair informação
- Acesso a recursos

Terminar

- Termina a relação com a vítima
- Remoção de vestígios



OBTENÇÃO DE INFORMAÇÃO



Fonte: <https://osintframework.com/>

DEEP FAKE

VOZ

VIDEO



Forbes

In early 2020, a bank manager in the Hong Kong received a call from a man whose voice he recognized—a director at a company with whom he'd spoken before. The director had good news: His company was about to make an acquisition, so he needed the bank to authorize some transfers to the tune of \$35 million. A lawyer named Martin Zelner had been hired to coordinate the procedures and the bank manager could see in his inbox emails from the director and Zelner, confirming what money needed to move where. The bank manager, believing everything appeared legitimate, began making the transfers.



OPEN SOURCE ELON

HERE'S HOW TO TURN INTO DEEPFAKE ELON MUSK DURING ZOOM MEETINGS

OR STEVE JOBS. OR THE MONA LISA.

Elon Musk

ALI ALIEV

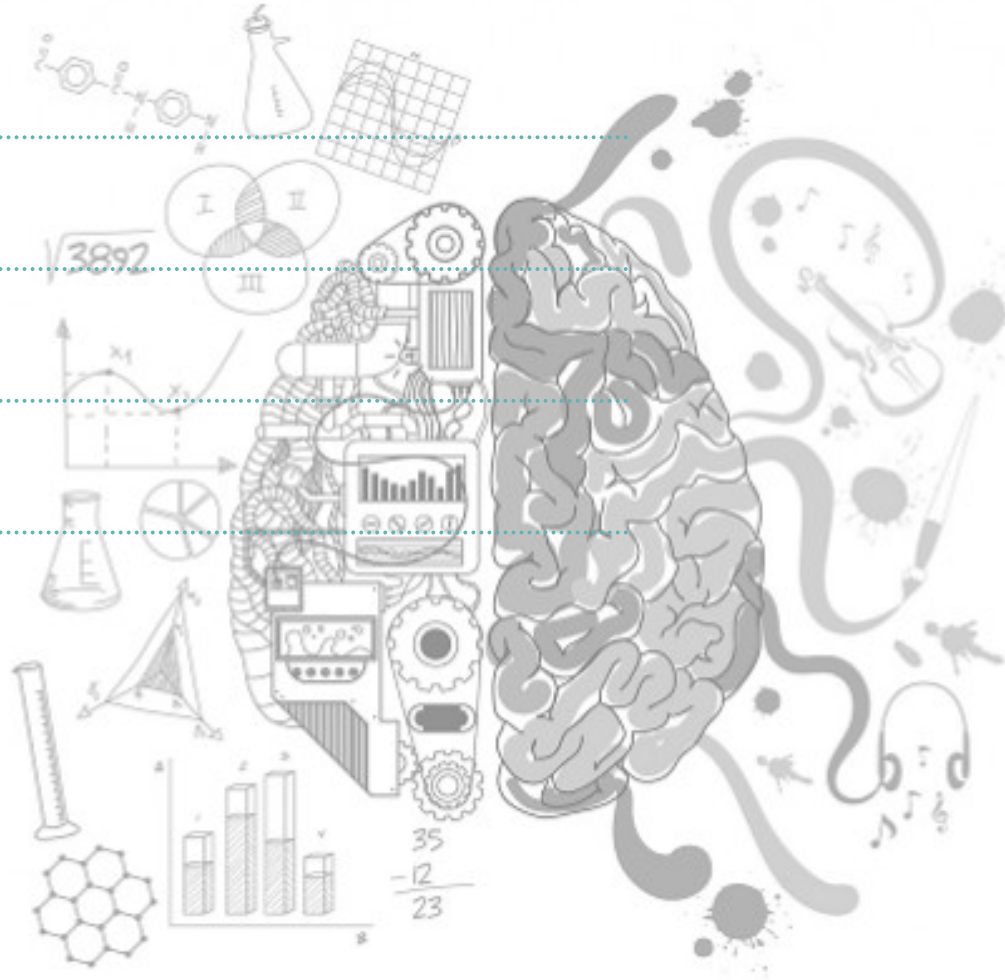
AGENDA

Princípios psicológicos

Engenharia Social

Exercício prático de Phishing

Conclusões



PHISHING

Utilizadores

~ 3500

From: Assistência de entrega DHL <dhl.delivery@tracking.fipsparcel.com>

Subject: Confirme o seu endereço de envio DHL

Attachment: [RECEIPT_PDF.doc](#)



NOTIFICAÇÃO DE ENVIO DHL EXPRESS

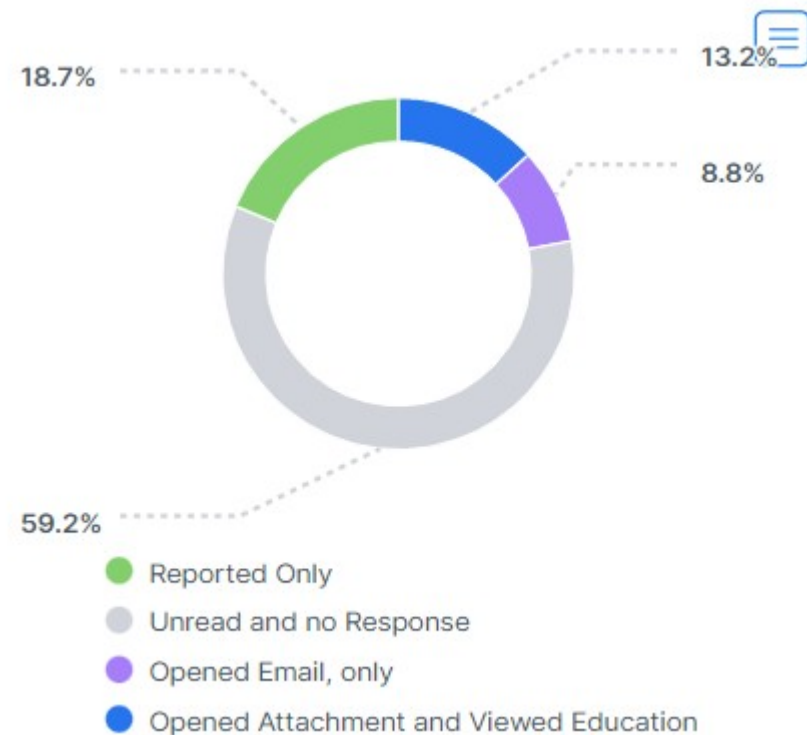
Caro destinatário,

Tem uma encomenda DHL, por favor confirme o seu endereço de envio.
Transfira o documento em anexo para confirmar as suas informações.

Se não confirmar o seu endereço de envio nas próximas 48 horas a sua encomenda não será entregue.

Se precisar de mais ajuda, contacte-nos.

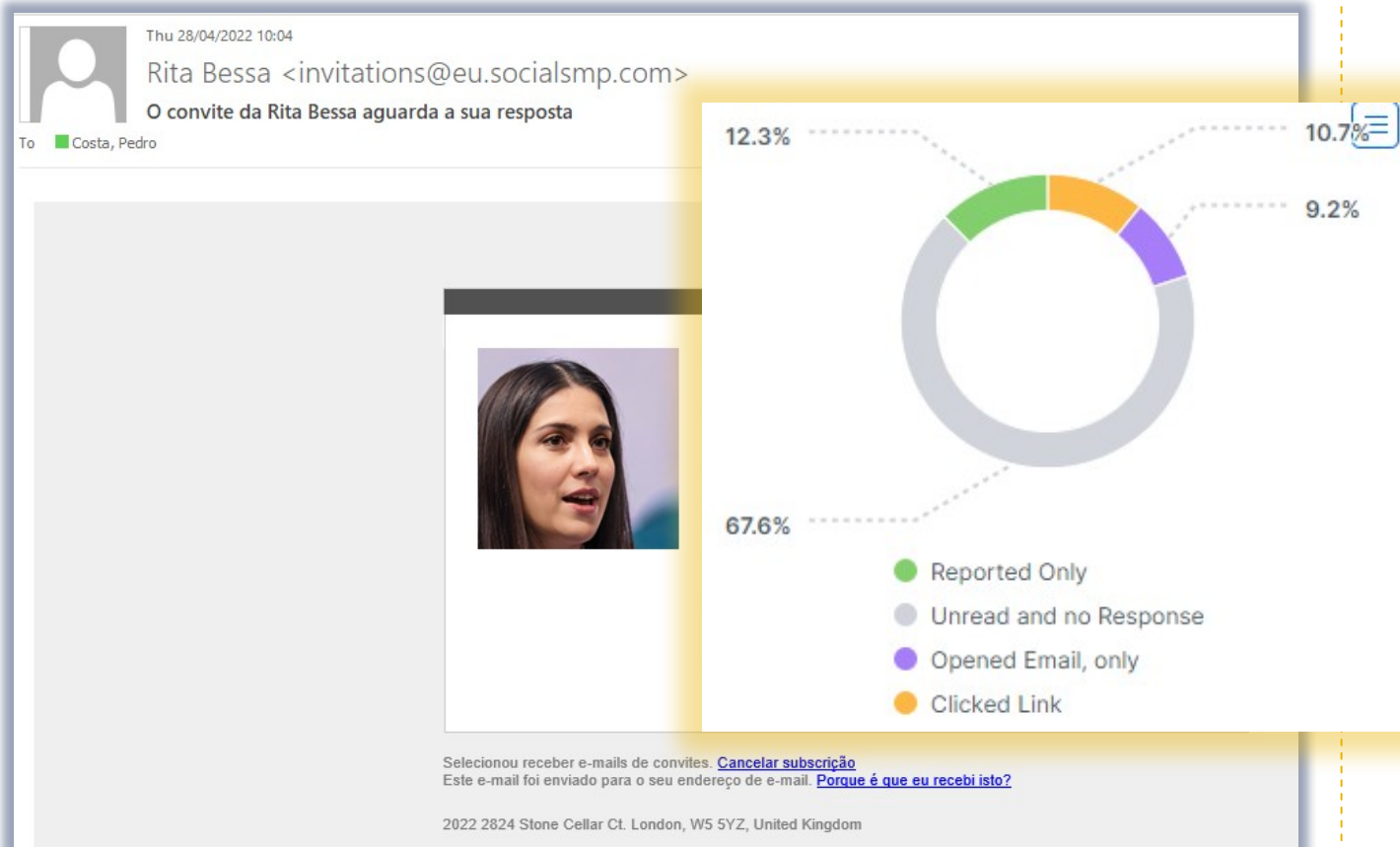
O nome e o logótipo DHL são marcas registadas e propriedade intelectual da DHL. A utilização das marcas registadas da DHL está sujeita a um acordo de licença.



PHISHING

Utilizadores

~ 600



ThisPersonDoesNotExist.com

Generative Adversarial Networks (GAN)

Inteligência Artificial – Algoritmo treinado em base a um enorme conjunto de dados (imagens)



Mas também existe o lado bom...

- Na Medicina (Detetar glaucoma precocemente, ...)
- Dar cor a imagens a P&B
- Mostrar como a aparência muda com a idade
- Gerar imagens em vez de as procurar

Scenario Start
Apr 28, 10:03:12 a.m.

First Susceptible
Apr 28, 10:05:19 a.m.

First Reporter
Apr 28, 10:06:01 a.m.

PHISHING

Utilizadores

~ 600

From: Lisa Estévez <connections@eu.socialsmp.com>

Subject: Solicitud de Oferta Comercial

Invitación de negocios

Tiene una invitación de negocios de **Lía Estévez**

*Estado: **Miembro verificado**

Mensaje:

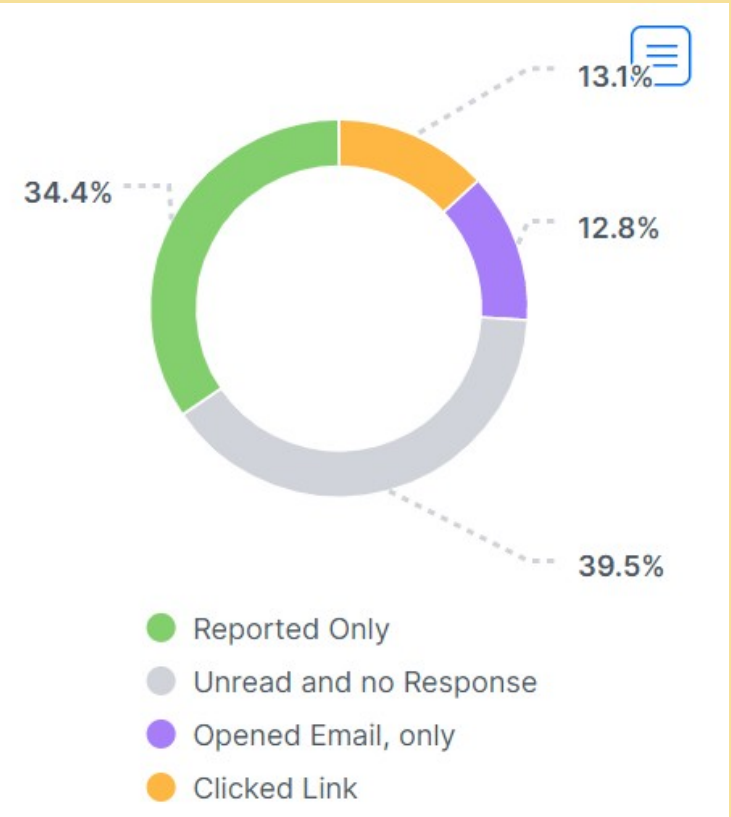
Estimado(a) .

Invitamos a su organización a presentar formalmente una oferta comercial que se describe en el documento de RFP, cuyo enlace adjuntados. Igualmente, le pedimos disculpas por el aviso tardío. Ver detalles de la solicitud*.

* Fecha de vencimiento del listado: 26 de mayo de 2022 a las 11:30 (Madrid)

Atentamente,
Lisa Estévez

[Ver detalles del contacto](#)



Scenario Start
May 23, 08:00:00 a.m.

First Reporter
May 23, 08:01:15 a.m.

First Susceptible
May 23, 08:01:34 a.m.

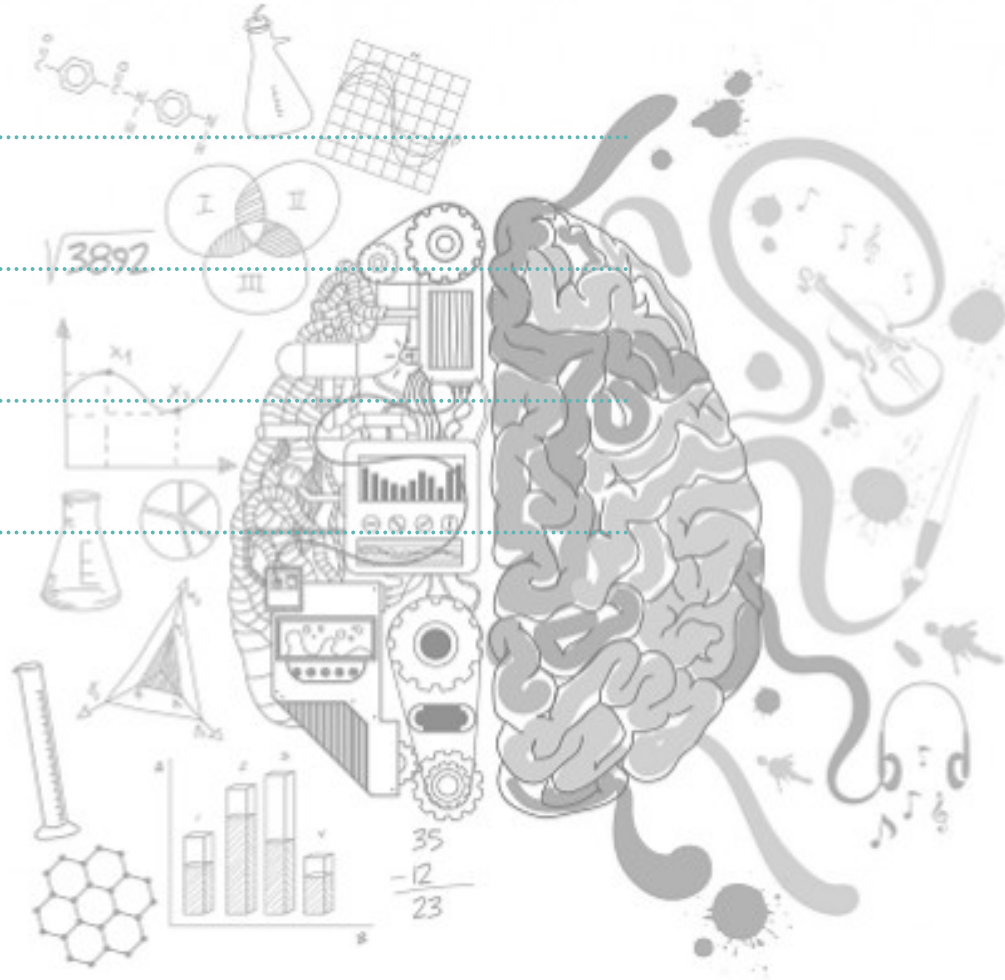
AGENDA

Princípios psicológicos

Engenharia Social

Exercício prático de Phishing

Conclusões



PHISHING

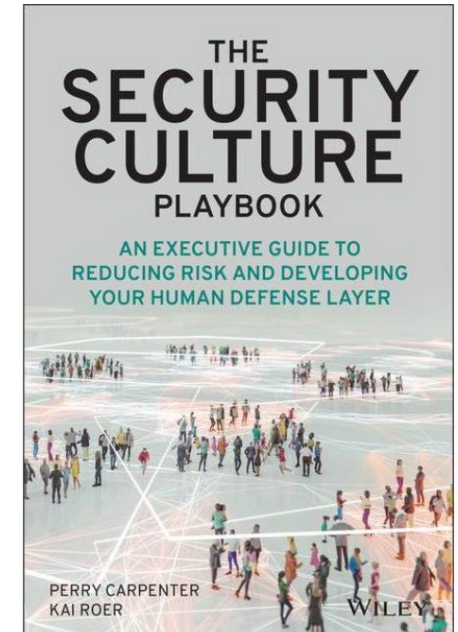
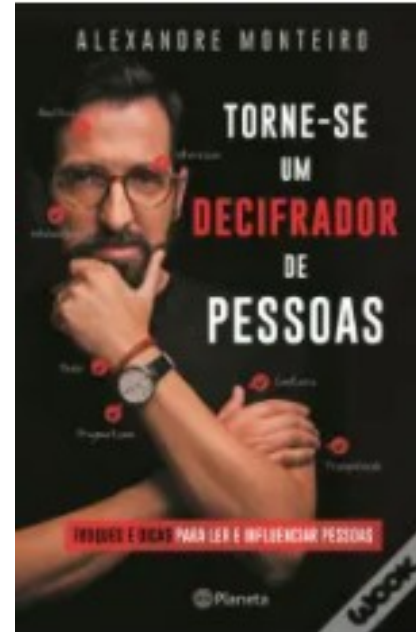
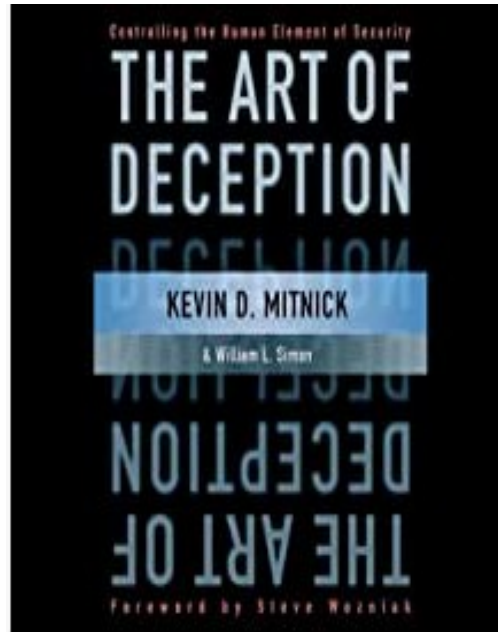
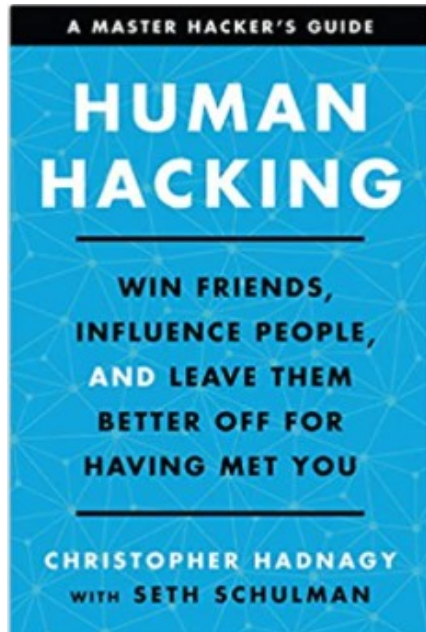
Principais conclusões

- As atuais formações online de sensibilização não são suficientes
- Promover a sensibilização específica para Phishing / Vishing / Smishing
- Utilizadores repetentes (> 4 campanhas em 1 ano)
- Promover o uso da opção de reportar email
- O utilizador desempenha um papel fundamental na segurança
- Nenhum tamanho serve a todos, cada ser humano tem o seu próprio pensamento

Questões em aberto...

- Com o stress diário, como melhorar a capacidade de distinguir os emails?
- Compensar os utilizadores? Reconhecimento, vouchers, outros?
- Informar previamente das campanhas de phishing?

LEITURAS RECOMENDADAS



SECURITY
THROUGH EDUCATION

<https://www.social-engineer.org/>



OBRIGADO!

**Porquê invadir algo...
quando se pode simplesmente pedir acesso?**